Secure development process

Gavel for Zoom Meetings · prepared 2026-10-20 · contact sankritya.apps@gmail.com

Gavel is built and maintained by one developer. The process below is what is actually done on every change, and the records that show it.

1. Every change

- Type checking (`tsc --noEmit`) and linting (`eslint`) must pass before commit.
- A 191-assertion automated suite (`npm run test:race`) runs against a local production build and again against the live site after each deploy. It covers bid races, expiry, identity forgery, bid privacy, webhook verification, host and co-host rules, max-bid contests, the lot queue, user removal and input validation.
- A separate end-to-end test covers Sign in with Zoom (OAuth 2.0 with PKCE) against a fake Zoom, including forged state, replay, a copied handshake cookie, open-redirect attempts and refused consent.
- Database changes are numbered SQL migrations in the repository (001 to 012). Every function that writes data is revoked from the public database roles and granted only to the server role.

2. Independent review of new server code

New code that touches identity, authorization or data is reviewed by a second, independent reviewer with no stake in the change, reading the code and its trust model. Three reviews were done in October 2026 (summarised in the security testing evidence). Findings were fixed or consciously accepted and documented.

3. Static analysis and dependencies

- GitHub CodeQL (`security-extended` query suite, JavaScript and TypeScript) runs on every push to the main branch, on every pull request and weekly.
- `npm audit --omit=dev --audit-level=high` runs on the same schedule and fails the build on a high or critical advisory in a shipped dependency.
- On 2026-10-19 Next.js was updated from 16.3.3 to 16.4.2 to clear one critical and several high advisories; the production audit has reported 0 vulnerabilities since.

4. Secrets and deployment

- Secrets (Zoom Client Secret and webhook Secret Token, the session-signing secret, the database service key) are Vercel environment variables. They are not in the repository.
- Production deployments are made from the repository by the developer. The Zoom Client Secret and webhook Secret Token are rotated in the Marketplace and in Vercel together.

5. Data handling by design

- Zoom user IDs are stored only as keyed hashes. No OAuth access or refresh token is stored.
- Sessions are deleted automatically after 24 hours (browser) or 30 days (meetings). When Zoom reports that a person removed the app, their data is erased.

6. Reporting a problem

Security reports go to sankritya.apps@gmail.com. Reports are read on business days.

Repository: github.com/SankrityaT/zoom-gavel · Workflow: .github/workflows/security.yml